Lab 5: Primer contacte amb un agent EDR (Wazuh)

Detecció d'amenaces

GEI | FIB | Curs 2026/2027

UNIVERSITAT POLITÈCNICA DE CATALUNYA
BARCELONATECH
Facultat d'Informàtica de Barcelona



UNIVERSITAT POLITÈCNICA DE CATALUNYA
BARCELONATECH
Facultat d'Informàtica de Barcelona

Detecció d'amenaces

Assignatura amb 22 hores de laboratori corresponent a l'especialitat:

Tecnologies de la informació

Inclosa en el:

Grau en Enginyeria Informàtica

Sobre mi

- **MANEL RODERO**
- Administrador de Sistemes, Universitat Politècnica de Catalunya:
  - UTGCNTIC [2019 – actualitat]
  - inLab FIB [2012 – 2019]
  - LCFIB [1996 – 2012]
- Analista de Seguretat, esCERT-UPC [2013 – 2017]
- Enginyer Informàtic, Facultat d'Informàtica de Barcelona [1999]
- Contacte:
  - manel.rodero@upc.edu

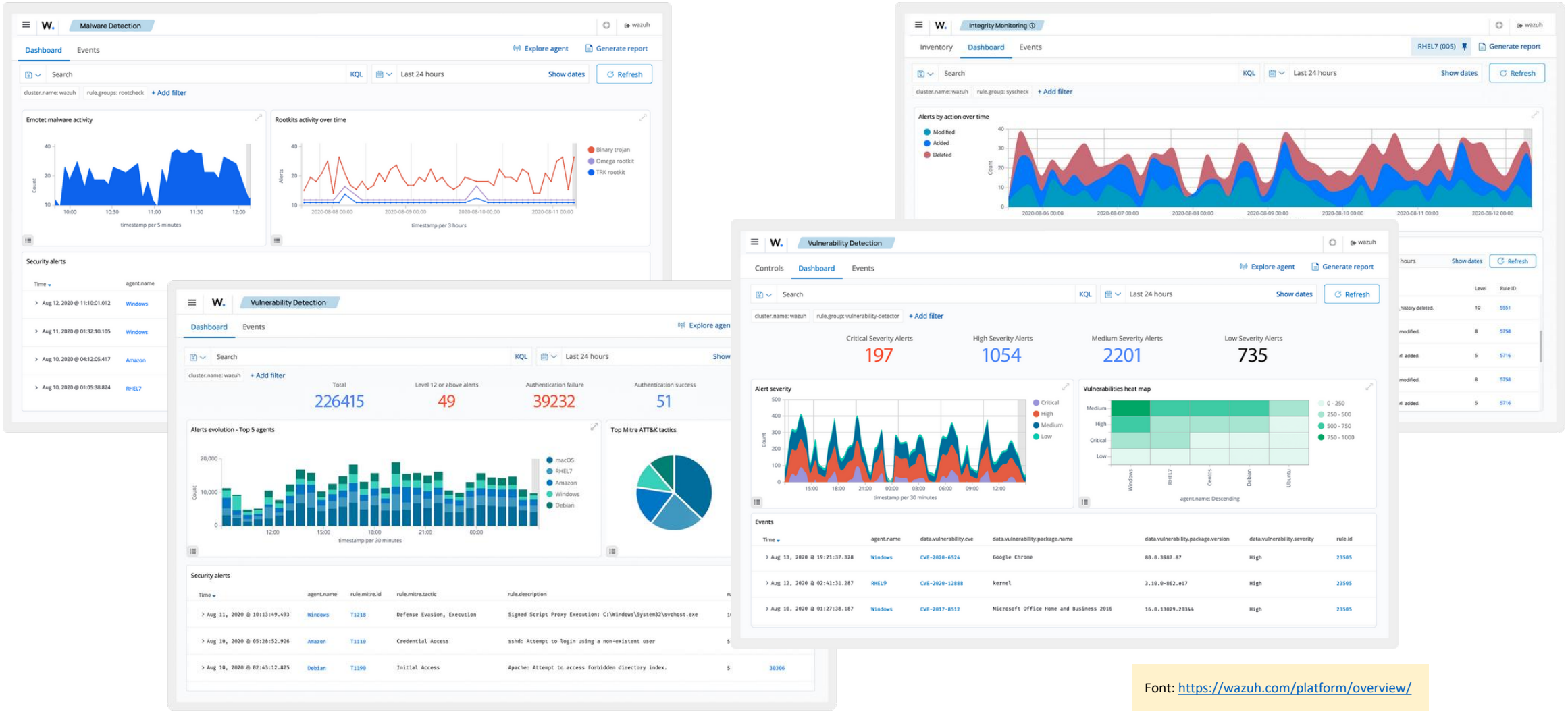
Lab 5. Primer contacte amb un agent EDR (Wazuh)

Configurar i mantenir aplicacions de detecció avançada a l'endpoint

Què és Wazuh?

- Plataforma **open-source** per a monitoratge, detecció i resposta
- **Wazuh** va néixer com un fork d'OSSEC HIDS (2015)
- Combina **HIDS + SIEM + XDR** en una única solució
- Recull i correlaciona **telemetria** dels endpoints
- Genera **alertes** i permet **respostes automàtiques**
- Integració amb **Elastic/OpenSearch** (cerca + dashboards)
- Compatible amb **Linux, Windows, macOS, contenidors** i **cloud**
- Detecta **activitat sospitosa**, vulnerabilitats i configuracions insegures

Overview



Font: https://wazuh.com/platform/overview/

Arquitectura

- **Agent**
  - S'instal·la a les màquines monitoritzades
  - Recull telemetria (registres, FIM, inventari, vulnerabilitats, etc.)
  - Si no es pot instal·lar → Syslog
- **Manager**
  - Servidor central que rep les dades
  - Les correlaciona amb regles de detecció i genera alertes
- **Indexer (OpenSearch)**
  - Emmagatzema i indexa les alertes/dades per a cerca ràpida
- **Dashboard**:
  - Interfície web per visualització d'agents, alertes, mòduls, etc.

Components i funcionalitats

Component	Funcionalitat
Regles de detecció	Signatures, comportament i correlació temporal
Active Response	Accions automàtiques (p. ex. bloqueig d'IP)
FIM (File Integrity Monitoring)	Canvis en fitxers/directoris
SCA (Security Configuration Assessment)	Auditoria de configuració
Vulnerability Detection	Correlació de paquets amb CVEs
Log Collection	Ingestió de logs del sistema i aplicacions
Integracions	MITRE ATT&CK, Syslog, APIs, compliance

Tot junt, a la teva pròpia VM

- Desplegament **"single-node"**: els 4 components en una sola VM
- En un entorn real d'empresa, cada component sol anar en una màquina diferent
- L'indexador pot arribar a ser un clúster de diverses màquines
- Objectiu d'avui: aprendre el funcionament complet amb recursos mínims
- Tecnologia de desplegament: **Docker** + **Docker Compose**
- Requisits recomanats per la VM:
  - Mínim 4GB RAM (6-8GB més segur)
  - 50GB de disc lliure

Què fa l'agent per defecte?

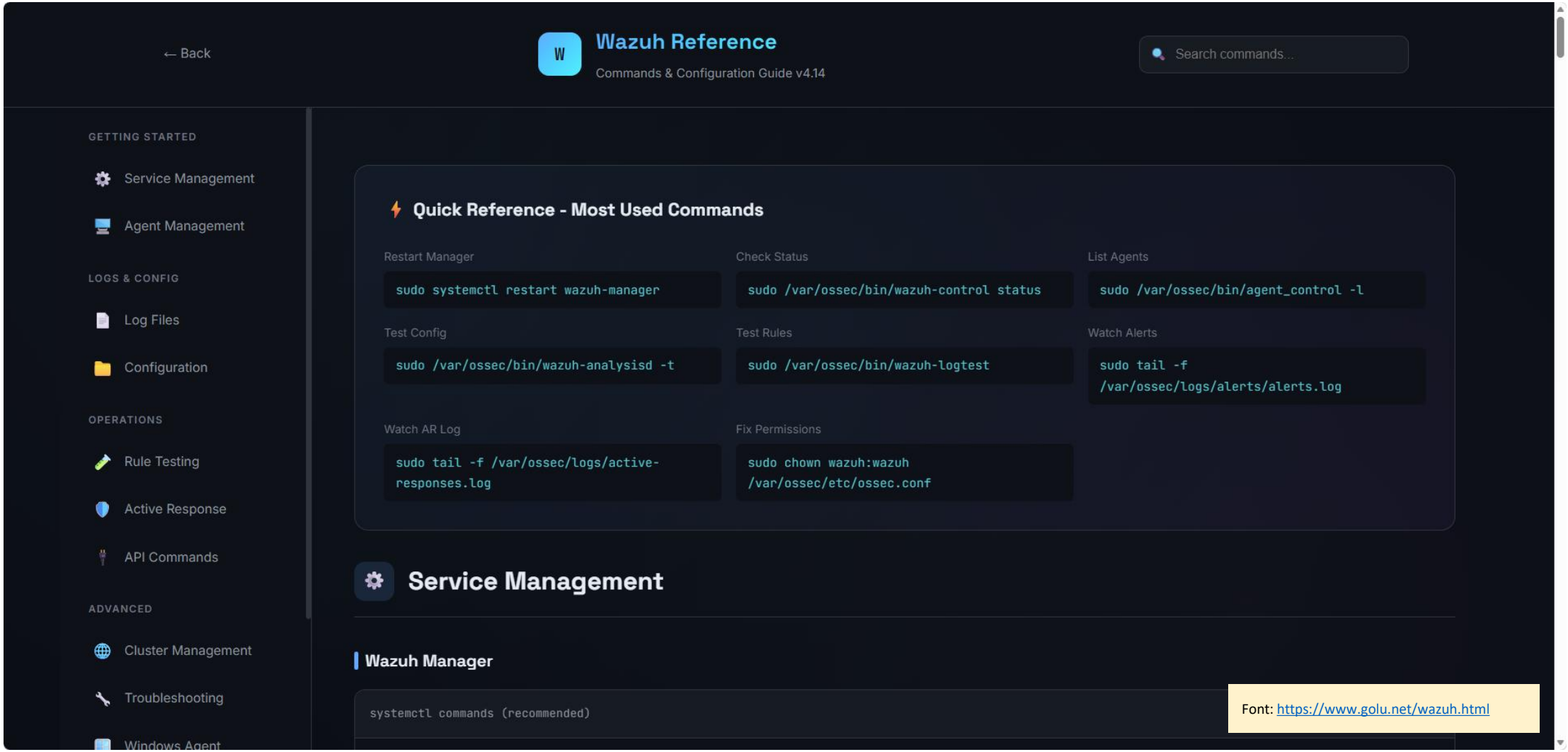
- **Log Collection**
  - Llegeix els fitxers de `/var/log/*` i `journalctl`
  - *Coneixement ja treballat a la sessió 3*
- **FIM** (File Integrity Monitoring)
  - Detecta canvis en fitxers i directoris
  - *S'aprofundirà a la sessió 9*
- **Rootcheck / SCA** (Security Configuration Assessment)
  - Comprovacions de configuració del sistema
- Tota aquesta informació s'envia al Manager per correlacionar-la amb regles

El cicle bàsic de Wazuh

- L'agent **recull dades** de l'endpoint (logs, FIM, configuració)
- Les **envia al Manager** (encara que sigui a la mateixa VM, via xarxa local)
- El Manager les **compara amb regles** de detecció
- Si hi ha coincidència, es **genera una alerta**
- L'alerta s'**indexa** (Indexer) i queda **visible al Dashboard**

Agent → Manager → Regles → Alertes → Respostes actives → Dashboard

Wazuh Reference



Font: https://www.golu.net/wazuh.html

Exercicis dirigits: Requeriments

- Desplegament de Wazuh mitjançant Docker (node únic)
- Requeriments:
  - Assegurar que la VM està actualitzada
  - Ampliar les **Virtual Memory Areas** (VMA) per l'indexador
    - Regió de memòria que permet accedir a fitxers del disc igual que en RAM
  - Confirmar l'**espai de disc** disponible
    - Almenys 50 GB d'emmagatzematge per a imatges de Docker i volums de dades
  - Confirmar la **memòria RAM** disponible
    - Almenys 8 GB de memòria RAM per a l'amfitrió Docker
    - Si la RAM confirmada és de 4GB, reduir el heap de l'indexador
  - Instal·lar **Docker Engine** a Ubuntu

https://github.com/manelrodero/FIB-GEI-DA/

Exercicis dirigits: Clonat repositori

- Clonar el repositori Docker de Wazuh
- Accedir al directori per desplegar-lo en un únic node
- Generar els certificats per assegurar la comunicació entre nodes
  - Certificats auto-signats de Wazuh (fem servir aquests per fer-ho senzill)
  - Els nostres propis certificats
- Revisar el fitxer `docker-compose.yml` i, opcionalment, canviar:
  - Mapeig local d'alguns volums
    - Per exemple, wazuh_etc i wazuh_logs
  - Contrasenya Indexer (**SecretPassword** és molt coneguda ;-)
  - Contrasenyes API i Dashboard
  - Memòria reservada per OpenSearch
    - -Xms1g -Xms1g

Exercicis dirigits: Volums i contrasenyes

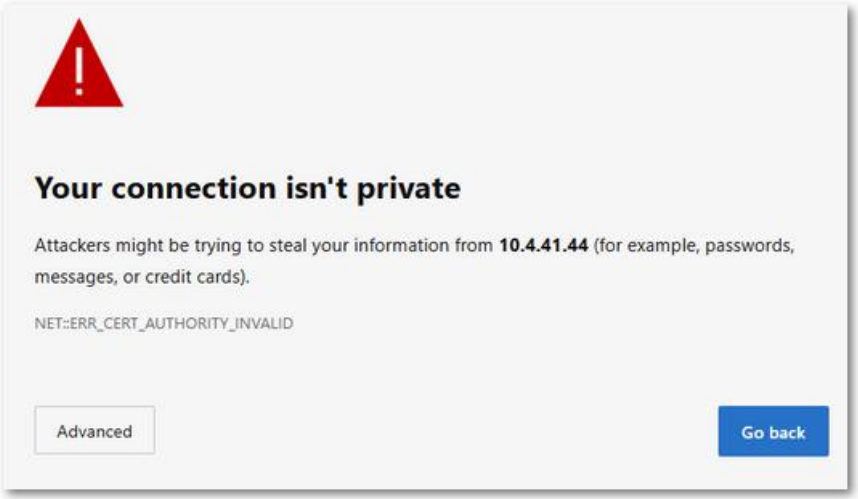
- Modificar el fitxer `docker-compose.yml`
  - Mapeig local dels volums wazuh_etc i wazuh_logs de Wazuh Manager
    - Facilita la revisió de configuracions i logs durant l'aprenentatge
  - Canviar la contrasenya de l'Indexer a Wazuh Manager i Wazuh Dashboard
    - Modificar les ocurrències de la variable INDEXER_PASSWORD
- Generar el hash Bcrypt de la nova contrasenya
- Modificar el fitxer `config/wazuh_indexer/internal_users.yml`
  - Hash de l'usuari admin

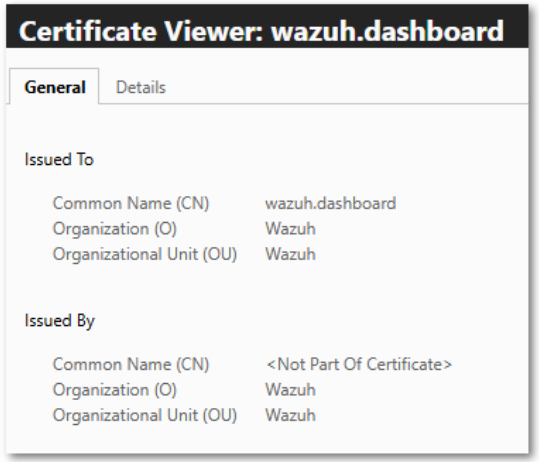


Font: https://stytch.com/blog/what-is-password-hashing/

Exercicis dirigits: Desplegament servidor

- Desplegar l'stack de Wazuh (~2-3 minuts)
  - Desactivar abans la recepció UDP/514 de rsyslog si està activada!
- Revisar la salut dels contenidors
- Revisar els logs i esperar fins que s'estabilitzi el servidor
- Si tot és correcte, accedir al Dashboard a `https://<Wazuh Host IP>`







Exercicis dirigits: Desplegament agent local

- Instal·lar un agent de Wazuh local
  - No desplegar l'agent amb Docker!
    - **Algú sap per què no?**
  - Apuntar al manager local amb WAZUH_MANAGER = <Wazuh_Host_IP>
  - Altres variables de desplegament que es cregui convenient
- Habilitar i posar en marxa el servei wazuh-agent
- Desactivar les actualitzacions automàtiques
  - Compatibilitat garantida si la versió de Wazuh Manager >= Wazuh Agent
- Verificar l'estat de l'agent

Exercicis dirigits: Comprovació

- Confirmar que l'agent apareix com actiu al Dashboard
  - Agents management > Summary
- Generar alertes "reals"
  - Executar l'script del Lab 3: `lab03_simular_registres_auth.sh`
- Localitzar les alertes al Dashboard i relacionar-les amb Labs anteriors
  - Threat Intelligence > Threat Hunting
    - Authentication failure
  - Agents management > Summary > Agent 001
    - MITRE ATT&CK
      - Tàctiques
        - Tècniques



Treball autònom en parelles



- El treball s'ha d'entregar en **1 únic fitxer PDF per grup** amb:
  - Fitxes completades
  - Comandes executades i resultat
- El nom del fitxer ha de tenir aquest format:
  - `Lab5_grupXX_Cognom1_Cognom2.pdf`
- L'entrega es fa mitjançant el **Racó**
- Teniu fins a la **mitjanit** del següent dimarts o divendres per entregar

Revisió d'una alerta (1 punt)

- Obrir les dues darreres alertes generades per l'script
  - sshd: authentication success / sshd: authentication failed
- Per cadascuna d'elles...
  - Indica quin nivell té? (Level)
  - Indica quina regla l'ha generada? (Rule ID)
  - Indica a quins grups pertany?
  - Explora la taula de valors o el format JSON i digues...
    - Què conté el full log?
    - Quin és el nom del decoder que s'ha utilitzat?
  - Explora la regla que ha generat l'alerta i digues...
    - En quin fitxer XML està definida?
    - Quin és el patró (pattern) que ha coincidit (match)?

Instal·lació d'un agent remot (1 punt)

- Instal·lar l'agent de Wazuh en una segona VM
- Comprovar als logs que ha pogut establir la connexió amb el servidor
  - Indica el contingut de les 5 línies de log relacionades amb aquesta connexió
- Comprovar que apareix al Dashboard
  - Quin identificador (Agent ID) ha rebut el nou agent?
- Aquest registre automàtic està obert a tothom
  - Quin servei ho permet i en quin port escolta?
- Quin fitxer de configuració de l'agent conté l'adreça del servidor?
- Quin port utilitza l'agent per comunicar-se amb el Manager?
- Observar aquesta comunicació amb tcpdump

Ports, dimonis i xifratge (1 punt)

- Llistar els ports que publica l'stack Docker i completar aquesta taula:
  - Port/protocol | Component | Funció
- Dins del Manager, executar wazuh-control status
  - Quins dimonis **no** s'executen?
  - Quin dimoni atén el registre, quin rep esdeveniments i quin aplica regles?
- Comparar el fitxer client.keys a un agent i al Manager
  - Descriure els 4 camps
- Capturar 2 paquets del port 1514 amb sudo tcpdump -A
  - Quina cadena llegible apareix al principi de cada missatge? Què indica?
- Connectar-se al port 1515 amb openssl s_client
  - Indicar el Subject, l'Issuer i la Duració del certificat. És auto-signat?

